

CYBERSECURITY INTERNSHIP

Name: Hammad Rasheed

ID: DHC-5590

Week 6

Security Audits

Step 1: Install OWASP ZAP

```
sudo apt update  
sudo apt install zaproxy
```

Start it:

```
zaproxy
```

The screenshot shows the ZAP interface in a Kali Linux virtual machine. The top window displays the 'Automated Scan' configuration page. The URL to attack is set to 'http://192.168.77.7:3000'. The 'Use traditional spider' checkbox is checked, and the 'Use ajax spider' dropdown is set to 'If Modern' with 'Firefox' selected. The 'Attack' button is visible. Below this, a table shows the scan results.

ID	Req. Timestamp	Resp. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Header	Size Resp. Body
563	6/9/26, 1:50:05 AM	6/9/26, 1:50:05 AM	GET	http://192.168.77.7:3000/media/28466039588...	200	OK	60 ms	467 bytes	9,903 bytes
565	6/9/26, 1:50:06 AM	6/9/26, 1:50:06 AM	GET	http://192.168.77.7:3000/rest/872131253297...	500	Internal Serve...	29 ms	363 bytes	1,838 bytes
567	6/9/26, 1:50:06 AM	6/9/26, 1:50:06 AM	GET	http://192.168.77.7:3000/rest/admin/5056443...	500	Internal Serve...	44 ms	363 bytes	1,850 bytes
569	6/9/26, 1:50:06 AM	6/9/26, 1:50:06 AM	GET	http://192.168.77.7:3000/rest/products/62922...	500	Internal Serve...	49 ms	363 bytes	1,856 bytes
571	6/9/26, 1:50:06 AM	6/9/26, 1:50:06 AM	GET	http://192.168.77.7:3000/socket.io/787019319...	400	Bad Request	29 ms	230 bytes	40 bytes
573	6/9/26, 1:50:06 AM	6/9/26, 1:50:06 AM	GET	http://192.168.77.7:3000/socket.io/?EIO=c%3A...	400	Bad Request	37 ms	92 bytes	18 bytes
574	6/9/26, 1:50:06 AM	6/9/26, 1:50:06 AM	GET	http://192.168.77.7:3000/socket.io/?EIO=c%3A...	400	Bad Request	37 ms	230 bytes	41 bytes

Step 2: Scan Your Application

app runs on:

<http://192.168.77.7:3000>

In ZAP:

1. Quick Start
2. Automated Scan
3. Enter your URL
4. Click Attack

Wait for completion.

Step 3: Run Nikto

Install:

```
sudo apt install nikto
```

Scan:

```
nikto -h http://192.168.77.7:3000
```

Save output:

```
nikto -h http://192.168.77.7:3000 > nikto-report.txt
```

```
(hammad@Kali)-[~]
$ nikto -h http://192.168.77.7:3000
- Nikto v2.6.0

+ Target IP:          192.168.77.7
+ Target Hostname:    192.168.77.7
+ Target Port:        3000
+ Platform:           Unknown
+ Start Time:         2026-06-09 01:54:00 (GMT5)

+ Server: No banner retrieved
+ ERROR: Failed to check for updates: 403
+ [999986] /: Retrieved access-control-allow-origin header: *.
+ [999100] /: Uncommon header(s) 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999996] /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
```

Step 4: Run Lynis

Install:

```
sudo apt install lynis
```

Run:

```
sudo lynis audit system
```

```
(hammad@Kali)-[~]
$ sudo lynis audit system

[ Lynis 3.1.6 ]

#####
Lynis comes with ABSOLUTELY NO WARRANTY. This is free software, and you are
welcome to redistribute it under the terms of the GNU General Public License.
See the LICENSE file for details about using this software.

2007-2025, CISofy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)
#####

[+] Initializing program
-----
- Detecting OS ... [ DONE ]
- Checking profiles ... [ DONE ]

-----
Program version:      3.1.6
Operating system:     Linux
Operating system name: Kali Linux
```

```
hammad@Kali: ~
- Scanning available tools ...
- Checking system binaries ...

[+] Plugins (phase 1)
-----
Note: plugins have more extensive tests and may take several minutes to complete

- Plugin: debian
[
[+] Debian Tests
-----
- Checking for system binaries that are required by Debian Tests...
- Checking /bin ... [ FOUND ]
- Checking /sbin ... [ FOUND ]
- Checking /usr/bin ... [ FOUND ]
- Checking /usr/sbin ... [ FOUND ]
- Checking /usr/local/bin ... [ FOUND ]
- Checking /usr/local/sbin ... [ FOUND ]
- Authentication:
- PAM (Pluggable Authentication Modules):
```

Step 5: Dependency Audit

Inside project folder:

```
npm audit
```

Fix what can be fixed:

```
npm audit fix
```

```
Kali [Running] - Oracle VirtualBox
File Machine View Input Devices Help
hammad@Kali: ~
npm audit fix --force
(hammad@Kali)-[~]
$ npm audit fix
up to date, audited 17 packages in 5s
# npm audit report
cookie <0.7.0
cookie accepts cookie name, path, and domain with out of bounds characters - https://github.com/advisories/GHSA-pxg6-pf5
2-xh8x
fix available via `npm audit fix --force`
Will install csurf@1.2.2, which is a breaking change
node_modules/cookie
  csurf ≥1.3.0
  Depends on vulnerable versions of cookie
  node_modules/csurf
2 low severity vulnerabilities
To address all issues (including breaking changes), run:
  npm audit fix --force
(hammad@Kali)-[~]
$
```

Step 6: Docker Security Scan

Install Trivy:

```
sudo apt install trivy
```

List images:

```
docker images
```

Scan your image:

```
trivy image <image-name>
```

Example:

```
trivy image juice-shop
```

Save results.

```
(hammad@Kali)-[~]
$ sudo docker images
REPOSITORY          TAG         IMAGE ID      CREATED      SIZE
bkimminich/juice-shop latest      1346770e24a8  3 weeks ago  365MB
mongo                4.4        0010f63d2695  5 months ago  409MB

(hammad@Kali)-[~]
$ trivy image fnimage
2026-06-09T02:04:10+05:00 INFO [vuln] Need to update DB
2026-06-09T02:04:10+05:00 INFO [vuln] Downloading vulnerability DB ...
2026-06-09T02:04:10+05:00 INFO [vuln] Downloading artifact ... repo="mirror.gcr.io/aquasec/trivy-db:2"
95.52 MiB / 95.52 MiB [----->] 100.00% 1.62 MiB p/s ETA 0s
```

```
(hammad@Kali)-[~]
$ trivy image juice-shop
2026-06-09T02:05:20+05:00 INFO [vuln] Vulnerability scanning is enabled
2026-06-09T02:05:20+05:00 INFO [secret] Secret scanning is enabled
2026-06-09T02:05:20+05:00 INFO [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-06-09T02:05:20+05:00 INFO [secret] Please see https://trivy.dev/dev/docs/scanner/secret#recommendation for faster secret detection
2026-06-09T02:05:23+05:00 FATAL Fatal error run error: image scan error: scan error: unable to initialize a scan service: unable to initialize an image scan service: unable to find the specified image "juice-shop" in ["docker" "containerd" "podman" "remote"]: 4 errors occurred:
* docker error: unable to inspect the image (juice-shop): Cannot connect to the Docker daemon at unix:///run/user/1000/podman/podman.sock. Is the docker daemon running?
* containerd error: failed to parse image reference: juice-shop
* podman error: unable to initialize Podman client: no podman socket found: stat /run/user/1000/podman/podman.sock: no such file or directory
* remote error: GET https://index.docker.io/v2/library/juice-shop/manifests/latest: UNAUTHORIZED: authentication required; [map[Action:pull Class: Name:library/juice-shop Type:repository]]

(hammad@Kali)-[~]
$
```

Step 7: Final Penetration Testing

Using lab application:

- Burp Suite
 - OWASP ZAP
 - Nikto
-